



Sound the Alarm: Detection and Response

Module 1

Incident: an occurrence that actually or imminently jeopardizes, without lawful authority, the confidentiality, integrity, or availability of information or an information system; or constitutes a violation or imminent threat of violation of law, security policies, security procedures, or acceptable use policies.

Event: An observable occurrence on a network, system, or device

All SECURITY INCIDENTS are EVENTS but not all events are security incidents.

5 W's of an Incident

- Who triggered the incident

- What Happened

- When the incident took place

- Where the incident took place

- Why the incident occurred

Incident handler's journal: A form of documentation used in incident response

Computer security incident response teams(CSIRT): A specialized group of security professionals that are trained in incident management and response

Incident response plan: A document that outlines the procedures to take in each step of incident response.

- Incident response procedures

- system information

Other documents

Incident response tools:

Detection and management tools

Documentation tools

Investigative tools

Documentation: any form of recorded content that is used for a specific purpose

Types of docs

Playbooks

Incident handler's journals

Policies

Plans

Final reports

Intrusion detection system (IDS): An application that monitors system and network activity and produces alerts on possible intrusions

Intrusion prevention systems(IPS): An application that monitors system activity for intrusions and take action to stop the activity.

IDS and IPS tools

Snort

Zeek

Kismet

Sagan

Suricata

Security information and event management(SIEM): An application that collects and analyzes log data to monitor critical activities in an organization

SIEM process

Collect and aggregate data

Normalize data

Analyze data

Security orchestration, automation, and response(SOAR): A collection of applications, tools and workflows that uses automation to respond to security events

Module 2

Network traffic: The amount of data that moves across a network

Network data: The data that's transmitted between devices on a network

Indicators of compromise (IOC): Observable evidence that suggests signs of a potential security incident

Data exfiltration: Unauthorized transmissions of data from a system

Defensive measures for data exfil:

- Prevent attacker access

- Monitor network activity

- Protect assets

- Detect and stop the exfiltration

Components of a packet:

- Header

- Payload

- Footer

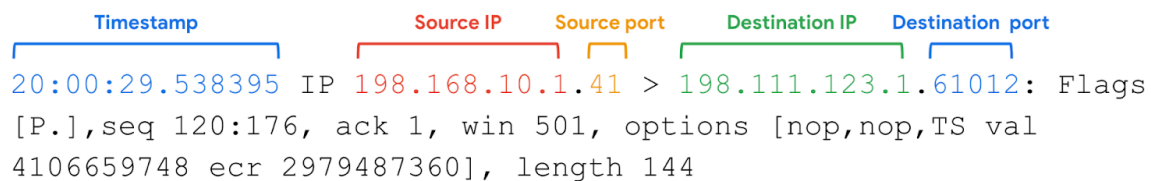
Network protocol analyzer(packet sniffer): a tool designed to capture and analyze data traffic within a network

Packet capture(P-cap): A file containing data packets intercepted from an interface or network

Fragmentation: when an IP packet gets broken up into chunks, which then get transmitted over the wire and reassembled when they arrive at their destination

TCP DUMP

1. Timeline: 20:00:29.538395
2. Version field IP: = IPv4
3. (TOS 0x10): TOS = Type of service / Value in hexadcimal
4. ttl: time to live = TTL / 64
5. ID / OFFSET / FLAGS: fragmentation = provide instructions for reassembling packets in correct order
6. proto: protocol in use and the value that corespondes with the protocol
7. length: total length of a packet including the IP header



The diagram shows a TCP dump line with color-coded fields and brackets above them. The fields are: Timestamp (blue), Source IP (red), Source port (orange), Destination IP (green), and Destination port (blue). The dump line is: 20:00:29.538395 IP 198.168.10.1.41 > 198.111.123.1.61012: Flags [P.], seq 120:176, ack 1, win 501, options [nop,nop,TS val 4106659748 ecr 2979487360], length 144

Module 3

Detection: the prompt discovery of security events

Analysis: the investigation and validation of alerts

Challenges in detection and analysis phase

1. Impossible to detect everything
2. High volume of alerts

Benefits of documentations

1. Transparency
2. Standardization
3. Clarity

Chain of custody: The process of documenting evidence possession and control during incident lifecycle

1. Description of evidence
2. Custody log

Broken chain of custody: inconsistencies in the collection and logging of evidence in the chain of custody

Types of playbooks:

1. Non-automated
2. Automated
3. Semi-automated

Triage: The prioritizing of incidents according to their level of importance or urgency

Triage process:

1. Receive and assess
 - a. Is the alert a false positive?
 - b. Was this alert triggered in the past?
 - c. Is the alert triggered by a known vulnerability?
 - d. What is the severity of the alert?
2. Assign priority
3. Collect and analyze

Containment: The act of limiting and preventing additional damage caused by an incident

Eradication: The complete removal of the incident elements from all affected systems

Recovery: the process of returning affected systems back to normal operations

Final Report: Documentation that provides a comprehensive review of an incident

Module 4

Logs: A record of events that occur within an orgs systems

Log details:

1. Date
2. Time
3. Location
4. Action
5. Names

Log analysis: The process of examining logs to identify events of interest

Log Types:

1. Network
2. System
3. Application
4. Security
5. Authentication

Logs contain:

1. Timestamps
2. System characteristics

3. Action

Commonly used log formats

1. Syslog

- a. Header
- b. Structure Data
- c. Message

2. JavaScript object notation (JSON)

- a. Key value pairs
- b. Commas
- c. Double quotes
- d. Curly brackets
- e. Square brackets

3. eXtensible markup language (XML)

- a. Tags

4. Comman Separated Values (CSV)

Telemetry: The collection and transmission of data for analysis

Packet captures are considered telemetry

Intrusion detection system (IDS): An application that monitors activity and alerts on possible intrusions

Endpoint: any device connected on a network

Host-based intrusion detection system: An application that monitors the activity of the host on which it's installed.

Network-based intrusion detection system: An application that collects and monitors network traffic and network data.

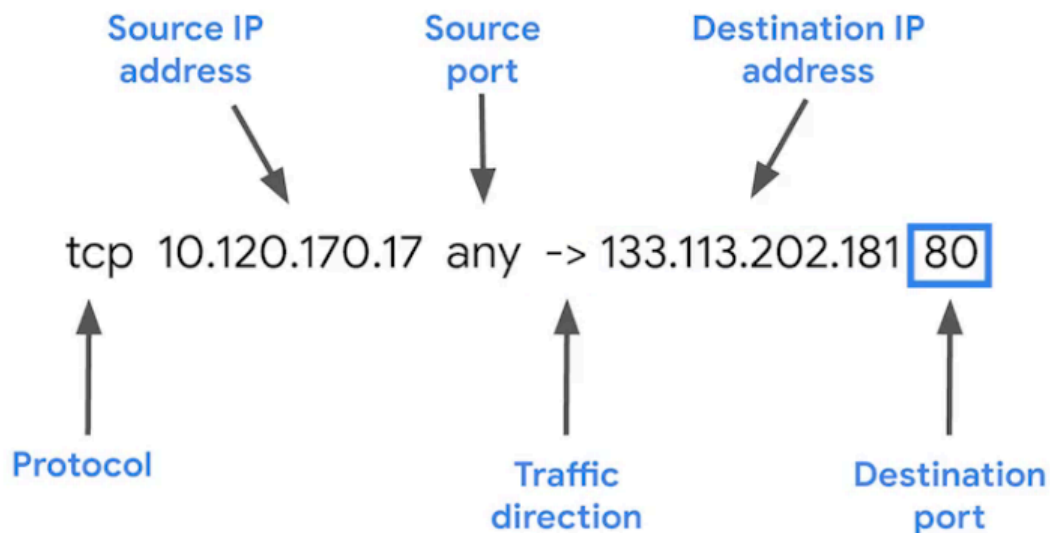
Detection techniques

- 1. Signature analysis: A detection method used to find events of interest

- a. Signature is a set of rules an IDS refers to when it monitors activity
- 2. Anomaly-based analysis: A detection method that identifies abnormal behaviors

Components of a NIDS rule

- 1. Action:
 - a. Determines the action to take if the rule criteria is met
 - b. Common: Alert, Pass, Reject
- 2. Header
 - a. Source and destination IP addresses
 - b. Source and destination ports
 - c. Protocols
 - d. Traffic Direction
 - e. ex:



3. Rule option

- a. in Parentheses, separated with semi-colons
- b. Msg
- c. Signature ID
- d. Revision

Suricata

Action	Header	Rule options
<code>alert</code>	<code>tcp 10.120.170.17 any -> 133.113.202.181 80</code>	<code>(msg: "Hello"; sid:1234; rev:1;)</code>

ex:

```
alert http $HOME_NET any -> $EXTERNAL_NET any (msg:"GET on wire";  
flow:established; content:"GET"; sid:12345; rev:1)
```

Suricata format type

1. EVE JSON - Extensible event format javascript object notation

Suricata log types

1. Alert logs
2. Network telemetry logs